CS4220 – System Administration and Security
Project Assignments – Part II

Case Study : Security Design for Healthcare Systems

Mathias LEFEBVRE
malef6335@usn.no

Louis BARTKOWIAK
lobar2860@usn.no

University of South-Eastern Norway, Campus Kongsberg

April 23, 2026

1 Introduction

The healthcare system involves a complex interplay of law, regulation and rules. The data of all the different clinics, hospitals and insurance mix together, and it is difficult to have a history on the patient's health record. In response to these challenges, early digital record-keeping technologies began to emerge in the 60s, this led to the Electronic Health Record (EHR) systems that we know.
Electronic Health Record systems serve as the digital backbone of modern healthcare, enabling secure storage, retrieval, and sharing of comprehensive patient data across providers. However, the increasing reliance on EHRs also raises significant security concerns. In this case study, we will discuss the security concern, how to design a robust security framework addressing identity management, authentication, access control, and authorization in adequacy with the Zero Trust principle.

2 System description and security needs

Electronic Health Records (EHRs), often used interchangeably with Electronic Medical Records (EMRs), represent the digital evolution of patients' paper-based health charts. Unlike Personal Health Records (PHRs), which patients control and update themselves. A patient EHR is created, managed, and held by a healthcare organization, accessible only to authorized clinicians involved in care delivery. Only healthcare professionals involved in patient care can access and use an electronic health record.

According to the International Organization for Standardization (ISO), the electronic health record (EHR) is a repository of information regarding the health status of a subject of care, in computer-processable form. The information can be retrospective, concurrent, and prospective. It can be transmitted securely and accessible by multiple authorized users [1]. The primary purpose of EHRs is to support continued, efficient and quality, integrated healthcare.

Basic EHR functionalities may include some secure messaging between patients and care teams for follow-ups and queries, E-prescriptions with refill requests, drug interaction checks, and dosage verification to replace handwritten scripts, centralized medical history management, progress notes, test results, speciality templates, and Personal Health Information (PHI) with legal audit trails, seamless test result delivery from labs to reduce errors and turnaround times, analytics for clinical insights, quality metrics, and evidence-based decisions and also an integrated dashboards for billing related information and finally, one of the main critical aspects is the Access

Control.

As medical data has gone from paper-based to electronic storage, it has become accessible by many more actors than before, and possibly a lot more people with bad intentions. Medical records are sensitive information as they contain a lot of patient's personal information, explaining why they are a prime target for hackers. Therefore their access needs to be highly regulated and protected.

As defined by the NIST [2], information security is the preservation of data confidentiality, security and integrity and availability. legislations such as the Health Insurance Portability and Accountability Act (HIPAA) in the USA and the General Data Protection Regulation (GDPR) in Europe mandate these 3 majors properties for electronic health records (EHR). Following these legislation's security requirements, and adding more security layers, is a must to have a strong and secure system. For data confidentiality PHI must be encrypted in transit and at rest to prevent data usage in case of data leak from the database. To prevent unauthorized employees from accessing sensitive data, a strict access control policy is needed, and if possible a User and Entity Behavior Analytics (UEBA) is highly recommended for a stronger prevention of insider threats. In terms of security of the data, accountability and traceability of data are essentials, for this, the system must have logs of data access, where, when and for which operation. On top of this, audit and anomaly detection must be implemented. Furthermore phishing and social engineering needs to be taken seriously, so a Multi Factor Authentication (MFA) and a Zero trust policy are mandatory points. Finally unauthorized modifications need to be prevented by using Digital signature, checksum or tamper-evident audits to ensure data integrity. It is also critical that data, especially patient information, is available at all times.

EHR, and especially highly secured EHR brings a lot of benefits to healthcare but their costs are high, though it can be impossible for small and even medium hospitals to implement.

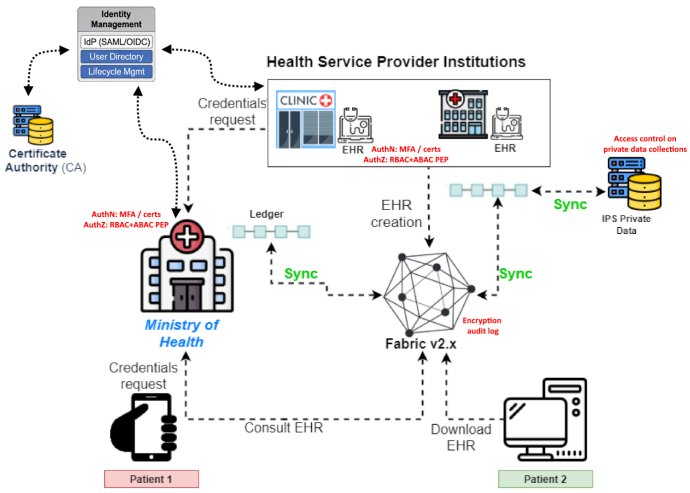

Fig1 : EHR system architechture diagram [3]

3 identity Management

Identity management represents a critical component of the security architecture of an EHR system, as it directly affects authentication, access control, and trust between healthcare actors. There are different identity management models that can be considered in a national healthcare context. The first one to be considered is Federated Identity and Access Management, the central Ministry of Health acts as the trusted Identity Provider (IdP) using OpenID Connect, with providers as Service Providers (SPs). Patients and staff receive federated credentials for

seamless SSO across EHRs and Fabric.
The second identity management model can be Centralized IAM with Blockchain Identities. Here the ministry hosts a master directory synced to Hyperledger Fabric ledger for tamper-proof identities like self-sovereign identities (SSI) for patients using verifiable credentials.
And the last possible model is a Hybrid Local-Federated IAM, providers manage local directories (LDAP/AD) federated to Ministry IdP where the patient matches via EMPI (Enterprise Master Patient Index) with blockchain for disputes.

For this case study, the federated identity management model was selected because of its scale for national multi-provider sync, balance scalability, trust, and regulatory compliance, while avoiding the complexity and overhead associated with blockchain-based identity management. The federated IAM model leverages the Ministry of Health as the central Identity Provider (IdP) and Certificate Authority (CA), with Health Service Provider Institutions acting as Service Providers. This federation can enable secure Single Sign-On (SSO) using OAuth2.0, across distributed EHR instances and the Hyperledger Fabric network, ensuring consistent identity verification for patients, clinicians (doctors, nurses), administrative staff, and institutions. An analysis of the lifecycle by the user group is presented below. Each group has the same process, creation, verification, management and revocation :

- For the patient he (or the hospital) initiates registration via the Ministry patient portal or provider front desk using verified government ID, biometrics (facial/fingerprint), and proof of address. The Ministry generates a unique patient identifier and issues activation code [2]. If the patient needs to be verified by the system, MFA (smart token, biometric authentication and SMS/email) can be used. Resulting in the digital identity getting stored as verifiable credential in the blockchain. Regarding access management, patients independently manage permissions through the dedicated application (update contact info, consent preferences etc. . .). And if revocation of their access is needed, for example, on death, account closure request, or inactivity. Then the system updates a digital blacklist of certificates deemed untrustworthy by their issuing Certificate Authority (CA) called Certificate Revocation List (CRL), and uploaded to the Fabric blockchain.
- The process for the medical staff is a little bit different, first for the creation, the provider's human resource submits verified credentials (like license, employment contract) to the Ministry via a secure API. If the Ministry approves then, generate a certificate and OpenID Connect account tied to the national practitioner registry. Concerning the verification we can also use MFA (biometrics and token) at login, Fabric smart contract validates certificate chain for cross-provider consults. For managing, the role attributes with the speciality and privileges are updated automatically from hospital's human resource to Ministry IdP. And because in these environments there are a lot of locum doctors, the system can give temporary access via just-in-time (JIT) federation. The revocation is automated on termination, and any disciplinary actions suspend certificates instantly, blocking all EHR/Fabric interactions.
- For the administrative staff, the process is similar to medical staff but scoped to non-clinical roles like billing or scheduling with a lower verification but still sufficient (just ID and employment proof). MFA is still required and privileges must be limited to aggregated data with no acces to PHI. May use faster revocation cycles in case of short term missions.

But this model can lead to some challenges inherent to distributed healthcare environments, where identities must span the Ministry of Health, multiple Health Service Provider Institutions, and patients accessing via mobile apps. The first one is to trust establishment and interoperability, because Providers must trust Ministry-issued credentials for cross-institution EHR consults and Fabric data syncs, but differing verification standards can create friction.
There is also the attribute privacy and minimal disclosure where sharing clinician roles or patient affiliations lead to a risk of PHI leakage. The solution to this could be to include Just-In-Time (JIT) attribute release, for example only "practitioner" or "on-duty" clinicians can consult patients informations according to the OAuth consent scopes, with zero-knowledge proofs on Fabric for verification without data exposure.
Another challenge is dynamic workforce and privilege creep. Locum doctors, rotating residents, and terminations require instant cross-domain updates. Thus it is important to correctly update information of the SCIM and eliminate stale access, while doing annual audits flag over-provisioning.

But one of the main issues is simply the patient Adoption and Usability, because elderly patients struggle with biometrics/wallets. Moreover hybrid flows plus self-service activation codes can lead to additional difficulty for them.
All this Identity management design leads us to a strong security, where important principles like least privilege are respected, indeed JIT provisioning releases only session-specific attributes, no standing roles across providers, enforced by Policy Decision Point (PDP) querying IdP and the Fabric state.
Additionally, the lifecycle management with these automated workflows ensure "create once, sync everywhere" and permanent monitoring flags stale accounts. Furthermore, as an admin perspective the dashboard shows provisioning queues and revocation stats.

4 Access control Policy

This part focuses on the Access Control Policy, for this kind of sensitive system it is important to implement a strong and resilient policy. For this case study, an hybrid RBAC / ABAC model was decided to be implemented. The roles define baseline permissions, and attributes refine decisions for Zero Trust and cross-provider use. A hybrid implementation has been decided instead of pure RBAC or pure ABAC because, firstly, pure RBAC do not have enough fine-grained and lack of flexibility, and implementing too specific roles might leads to a too complex system. Secondly, a purely ABAC-based approach introduces significant complexity due to extensive verification requirements. Therefore, a hybrid approach is adopted. The RBAC filters a lot first and the ABAC adds a more fine-grained decision layer. The RBAC model defines several distinct roles, A small and clear role set is designed at national level, then extended with their own attributes.

The implemented roles are : patient, doctor, nurse, admin staff, HR manager, provider IAM administrator, Pharmacist, lab technician, locum. The Ministry IdP, assigns each staff member a primary role and employer attribute during provisioning, HR changes (promotion, transfer, termination) are synced via SCIM and automatically update roles. Each provider's EHR, maps national roles to local permissions. A central Policy Decision Point (PDP) evaluates ABAC rules using attributes from the IdP, EHR, and Fabric and returns allow/deny while Policy Enforcement Points (PEPs) in the EHR UI, APIs, and Fabric gateways enforce the result. Furthermore, department heads can do periodic access reviews, with reports, listing each individuals role and can approve/downgrade them; orphaned or unused accounts trigger automatic revocation workflows. The first layer of our access control policy, based on RBAC, reviewed, we can go to the second layer which is the ABAC.

Each groups have their own attribute, for example for clinicians the user attributes contains the employer, the profession and the current shift status (on-duty/off-duty). For the context attribute we have location (inside hospital, remote), time of access and risk score (low, medium, high). Patients have different attributes: a list of authorized hospitals, if the patient is minor, a list of authorized treating staff and if the patient is flagged as sensitive (celebrity, politician etc...). Each of these attributes can cover all the different users of the medical environment with their own specific access according to their need.

To illustrate this system, let is start with a first example. We have a doctor, working at a hospital H_1, and assumes he wants to access patient A's clinical records. The basic conditions to be able to access this record are the patient affiliation with the hospital H_1, the doctor is right now on duty, and is in the patient A treating staff. If the doctor is able to read/write the patient's record he will need to enter the log reason "treatment" for any change.

Continuing with a second example, we can look at a receptionist working in hospital H_1, welcoming a patient B. The receptionist can see at which hospital the patient is affiliated, its treating staff and its appointments. The only documents the receptionist is able to access, with reading and writing authorization is the appointment schedule of the patient and of each physician in the hospital H_1.

Last example, in a doctor's office, a doctor needs to be replaced by a locum doctor for 2 days. In this case, it is not possible to let the locum doctor access all doctor's information. The locum is only able to access its daily patients records, and only from the doctor's main device. Any modification will be noticed with a specific log in-

dicating that it is from a locum doctor. For more security, the session will only be accessible during fixed working hours, no extra hour is possible.

But sometimes there are some exceptional situations where temporary emergency access like a “break glass” is needed. Our system can handle this kind of situation but with additional security measures. Here is an example of how an emergency situation might unfold : firstly the user must explicitly choose “Emergency access / break-glass” in the EHR UI. After that the system forces a re-authentication with step-up MFA with password and hardware token or biometric, a mandatory entry of free-text justification with the reason and the context is needed, and the risk level must be low. If all these conditions are respected, then the user will have a limited time-bound scope and automatic rollback to normal policy afterwards.
This kind of emergency session grants Per-Patient read-only access to the full clinical record from all providers in Fabric. Moreover all actions in this mode are tagged with a special flag in both the local EHR audit log and the Fabric ledger in order to always know which data has been accessed during this session. Note that if the patient is a sensitive patient, then an authorization from the department chief approval is needed.

5 Authentication Mechanism

Given the presence of highly sensitive data handled by the system, a strong authentication mechanism is required. Aligned with NIST SP 800-63-4 [4] to meet the required security level, the decision was made to use a federated SSO with the Ministry IdP as the central Identity Provider and an adaptive MFA. The EHR platform hosts multiple applications, each acting as a Service Provider (SP). Regardless of the user role, the authentication approach will be the same, they use MFA to authenticate against the IdP, then the IdP issues an OpenID Connect compliant token containing the user attributes. Each EHR portal validates the token and establishes a local session allowing seamless access without requiring re-authentication until the session expires.

While the authentication approach does not change, the authentication mechanism will change depending on the user’s group in the system. Starting with the case of a patient, to connect to the patient portal, the user will start with a classic primary login using an email/phone number as username and entering his password. Once the right login/password combination is entered, comes the second factor with an email/SMS One-Time Password. When connected, if the patient wants to access his PHI or to make account changes, another biometric MFA is needed. Next case, the Clinical staff, when they connect to their session for the first time of their shift, they identify themself with a national healthcare ID, given by the Ministry, and enter their password. After this, they have a context-dependent second factor, if the connection is from a hospital’s device then the staff member uses his badge to complete the MFA, but if the connection is from outside the hospital or from an unknown device, the MFA will be done through a push notification to a mobile app. Once connected, clinicians can lock/unlock their session only using their badge on a workstation, the sessions have an automatic timeout lock-in, which length depends on the accessibility to the public of the area. This system enables fast and easy usability without compromising security. Finally for the most privileged role, the authentication needs to be stricter, for each connection, a strong password and a hardware token, such as a badge, like for the clinicians, is required. Any access from an unmanaged device is systematically denied, for any sensitive actions such as role change of PDP rule edit, a re-authentication is needed.

In this context, the risks associated with credential theft and impersonation are heightened, according to a meta-analysis carried out in 2024 by Philip Khasuntsev "90% of all the organizations worldwide have been targeted by cybercriminals and have received phishing emails" [5], which motivates the design of a system with enhanced robustness.
A risk score is implemented in the system, this allow to do authentication of the user using a dynamic scoring engine at the Ministry IdP. This engine calculates threat levels in real-time using factors like untrusted network login (+2), off-hours access (+1), unmanaged device posture (+3), recent failed logins (+2), unusual locations (+1), and foreign geolocation (+3), with thresholds triggering graduated responses.

For example if Dr. John from Hospital A working remotely, a coffee shop login yields a risk score of 8, it will be considered as High, enforcing step-up biometric MFA, read-only access, 15-minute timeouts, and SIEM

alerts to block phishing victims from Fabric writes.
Instead, Dr. John connection from his home with a VPN, scores 3 so it will be considered as Low, he will have regular access.
And by contrast, if he connects from a foreign IPs, with recent failed login and during off-hours, then this will hit 10 and will be considered as Critical, with immediate lockout and Certificate Revocation List (CRL) propagation. Any high-risk sessions are rejected by Fabric smart contracts. This protects against phishing, device theft, account takeover, and insiders, ensuring compromised credentials never poison the national ledger, through continuous verification, ML anomaly detection, mTLS token binding, and immutable Fabric audit trails.

6 Authorization framework and Zero Trust

This Zero Trust Authorization Framework integrates easily in our system. Currently the federated IAM (Ministry IdP), hybrid RBAC/ABAC policy, and risk-adaptive authentication lead to a cohesive Policy Decision Point (PDP)/Policy Enforcement Point (PEP) architecture.
Every access request is dynamically evaluated using fresh identity claims, patient attributes, and context signals, ensuring the "never trust, always verify" across EHRs and Fabric.

In the PDP/PEP Model, the Policy Decision Point (PDP) is the part that does the evaluation and check if the user has the authorization to access to each data. This part is centralized in the Ministry Authorization Service, it receives authN token (OpenIDConnect) from IdP with user claims such as the role, the employer or the licence and queries Fabric ledger for patient attributes like assigned staff, minor status or if the patient is a sensitive one. They collect context, like location and time from edge PEP and calculate de risk score, then the evaluation with hybrid RBAC/ABAC policy is done. The evaluation process results in an authorization decision and returns specifying if the access is authorized or denied, the score (read/write), the time to live, and the risk score. This decision is finally transmitted to the Policy Enforcement Point (PEP).

Unlike the PDP, the PEP does not make authorization decisions, its role is limited to enforcing the decision received from the PDP. This part is ensured by EHR UI/API gateway, the Fabric API gateway and the patient portal. The PEP Intercepts all requests and forwards them to PDP, enforces PDP response (permit/deny/redirect) and applies obligations like log or audit tag.

The framework supports secure decision making through the PDP/PEP model's evaluation process in both normal and exceptional scenarios. Normal operation represent the majority of the traffic and is correctly handled by the system. The PDP at the Ministry Authorization Service gathers fresh data from multiple trusted sources to evaluate hybrid RBAC/ABAC policies, producing cryptographically signed decisions that PEPs enforce with confidence and ensuring no stale permissions or implicit trust, even on internal networks.

For exceptional emergency cases, the framework activates specialized break-glass policies when physicians explicitly trigger emergency access, via step-up MFA and justification entry. The PDP then applies narrowed evaluation criteria as described before. Fabric smart contracts provide secondary enforcement to prevent ledger tampering, maintaining decision integrity, through immutable audit trails thus guaranteeing reliable and tamper-proof authorization, even under crisis conditions without compromising baseline security.
Another emergency case is a Ministry PDP outage, then the system will use local cached low-risk decisions, emergency read-only mode for physicians (local patients only) in order to avoid malicious users to use network failure.

Zero Trust principle relies on different key features : Verify explicitly, Never trust, always verify, Least privilege access, Assume breach, Strong identity as the security perimeter, Micro-segmentation, Continuous monitoring and re-evaluation. The framework reflects these core principles through targeted security mechanisms. Verify Explicitly is enforced by the PDP's continuous evaluation of every request by using fresh IdP claims, Fabric patient attributes, and real-time risk scores, also by rejecting network-based trust assumptions even internally, and finally by requiring step-up MFA mid-session if risk increases. Least privilege means each person only gets the access they really need, for example as seen previously a locum doctor can only see their patients for the day

from approved devices. Least privilege examples are also the case of nurses who cannot write prescriptions and administrative staff who cannot view medical details. All those access are also dynamically narrowed by context, such as on-duty status or low-risk only. Assume Breach drives risk-adaptive step-up MFA, Fabric smart contracts rejecting dangerous changes even if PDP fails, and permanent and immutable audit trails that prove what happened and grant non-repudiation. Lastly, Per-patient emergency scoping eliminates VIP snooping. All those points collectively ensure that no single failure compromises national PHI integrity.

7 Conclusion

To conclude, this comprehensive security design correctly identifies and addresses key aspects like identity lifecycle management, authentication, access control, and Zero Trust authorization. While creating a robust framework and future-proof foundation capable of scaling nationally that can ensure safeguarding patient trust.

References

[1] "Health informatics — Electronic health record — Definition, scope and context," Oct 2005.

[2] M. Nieles, K. Dempsey, and V. Pillitteri, "An introduction to information security," NIST Special Publication SP 800-12 Rev. 1, National Institute of Standards and Technology (NIST), Jun 2017.

[3] E. A. Pineda Rincón and L. G. Moreno-Sandoval, "Design of an architecture contributing to the protection and privacy of the data associated with the electronic health record," *Information*, vol. 12, no. 8, 2021.

[4] D. Temoshok, Y.-Y. Choong, R. Galluzzo, C. LaSalle, A. Regenscheid, D. Proud-Madruga, S. Gupta, and N. Lefkovitz, "Nist special publication 800-63-4: Digital identity guidelines," NIST Special Publication SP 800-63-4, National Institute of Standards and Technology (NIST), Jul 2025.

[5] P. Khasuntsev, "Effectiveness of phishing in healthcare: A meta-analysis," B.S. thesis, University of Twente, Faculty of Science and Technology (TNW), Enschede, The Netherlands, 2024. BSc Thesis, "Effectiveness of phishing in healthcare: A meta-analysis".

[6] M. Abbas, *Evaluating the Impact of IAM Implementations*. PhD thesis, Marymount University, 2026.

[7] T. Seymour, D. Frantsvog, and T. Graeber, "Electronic health records (ehr)," *American Journal of Health Sciences*, vol. 3, no. 3, p. 201, 2012.

[8] R. E. Gliklich, N. A. Dreyer, and M. B. Leavy, "Registries for evaluating patient outcomes: a user's guide," 2014.

[9] R. E. Gliklich, N. A. Dreyer, and M. B. e. Leavy, "Managing patient identity across data sources," in *Registries for Evaluating Patient Outcomes: A User's Guide*, Agency for Healthcare Research and Quality (US), 3 ed., 2014. Bookshelf ID: NBK208618.